GRCompliance · ComplianceOS

State of Startup Security 2026

What recently funded SaaS companies show the public — and what enterprise buyers check first.

A public-signals study of 104 Seed to Series A/B SaaS companies, with a deep check of 17 companies that showed no public SOC 2 or ISO 27001 signal.

14 October 2026 · Europe/Sofia

43%	3.26	0%	100%
have a public SOC 2 / ISO / trust-center signal (n=104)	mean public-trust score out of 10 (deep sample n=17)	of the deep sample scored Advanced (≥ 7.5 / 10)	had no working security.txt or disclosure page

1. Method and limits

This report combines two layers of publicly observable evidence. No company was contacted, and no system was accessed beyond ordinary browser and HTTP requests.

Layer A — Broad scan (n = 104)

We reviewed the websites of 104 Seed-to-Series-A/B SaaS companies that raised between April and October 2026 (list in targets_saas.csv). For each site we looked for public mentions of SOC 2, ISO 27001, or a trust centre on the homepage and common /security and /trust paths. Result codes: yes (signal found), no (no signal), unknown (site unreachable or inconclusive).

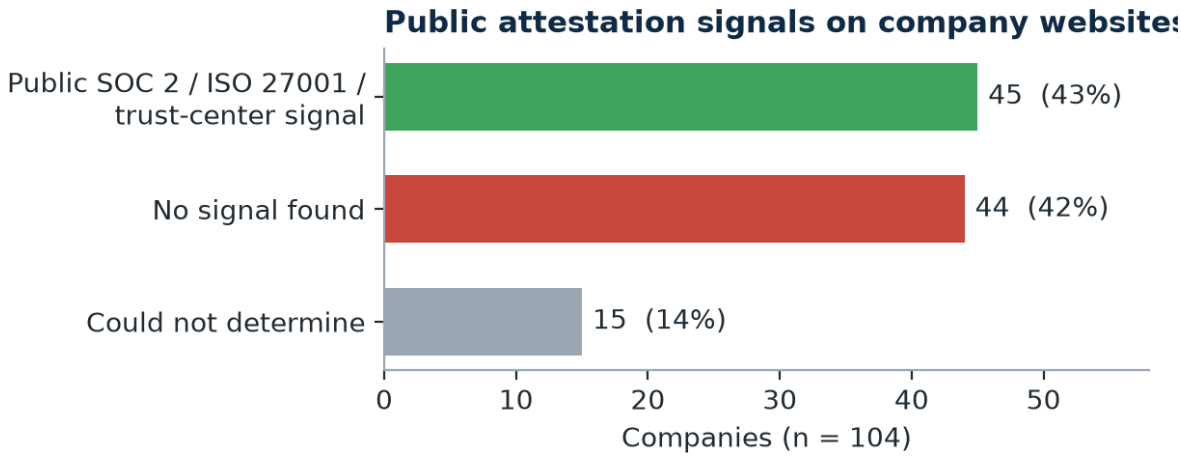
Layer B — Deep check (n = 17)

From the companies marked 'no', we ran a 10-signal passive check on 17 companies (one company was skipped as outside the funding criteria; three were excluded after being reclassified as 'yes'). Signals covered: trust/security page, SOC 2/ISO claim, privacy policy, subprocessor list, DPA, security.txt, HTTPS & six standard security headers, SSO/MFA mention, public status page, and cookie consent. Scoring: Found = 1, Partial = 0.5, Missing = 0. Early ≤ 4 · Developing 4.5–7 · Advanced ≥ 7.5.

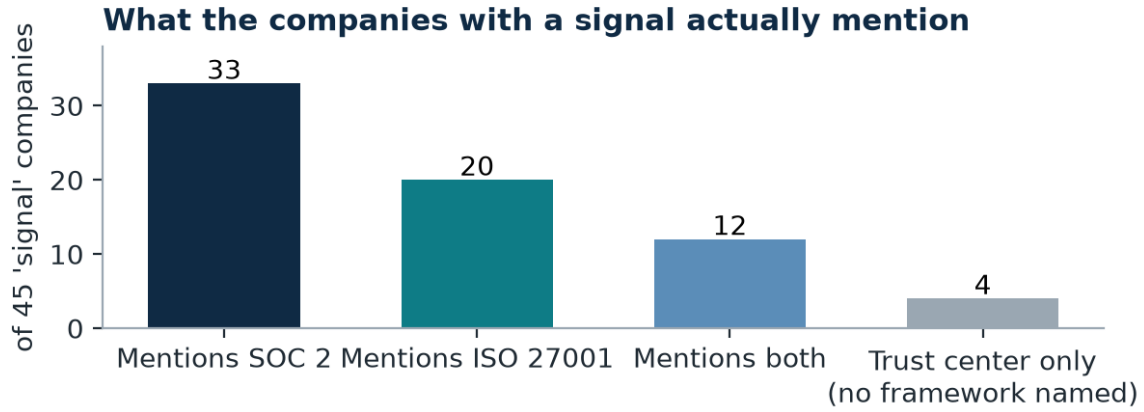
Limits. Findings reflect what is publicly visible, not what companies operate privately. Headers were checked on marketing sites only. Cookie banners were inferred from page code and a headless browser, not from a visual check in every EU locale. Two companies in the 'no' deep sample publicly claimed SOC 2 without a report path — counted as Partial. This is not an audit, attestation or legal advice.

2. Headline findings

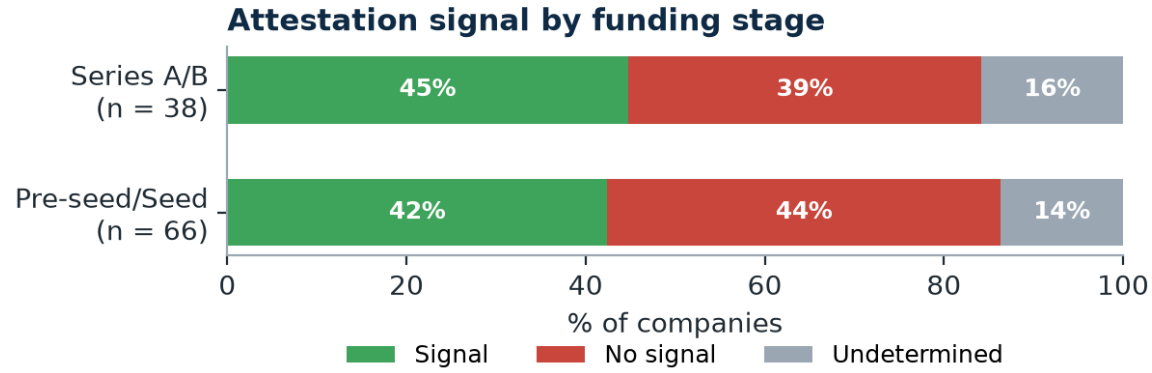
Of 104 recently funded SaaS companies, 45 (43%) show a public SOC 2, ISO 27001 or trust-center signal. 44 (42%) show none. 15 (14%) could not be determined.



Among the 45 companies with a signal: 33 mention SOC 2, 20 mention ISO 27001, 12 mention both, 18 reference a trust centre, and 4 show only a trust centre with no named framework.

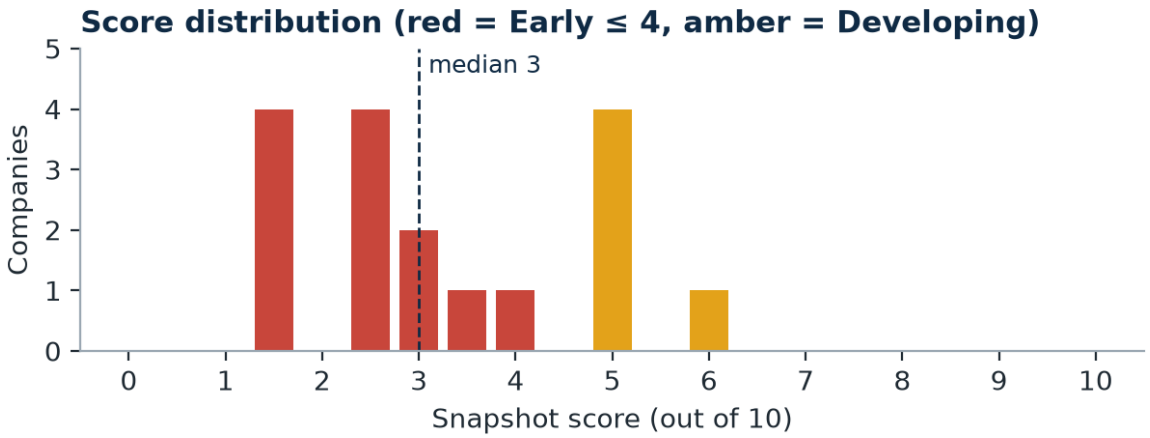


By stage, Pre-seed/Seed companies show a public signal 28/66 of the time (42%). Series A/B companies show one 17/38 of the time (45%). The gap is modest: raising a Series A does not, by itself, produce a public attestation.

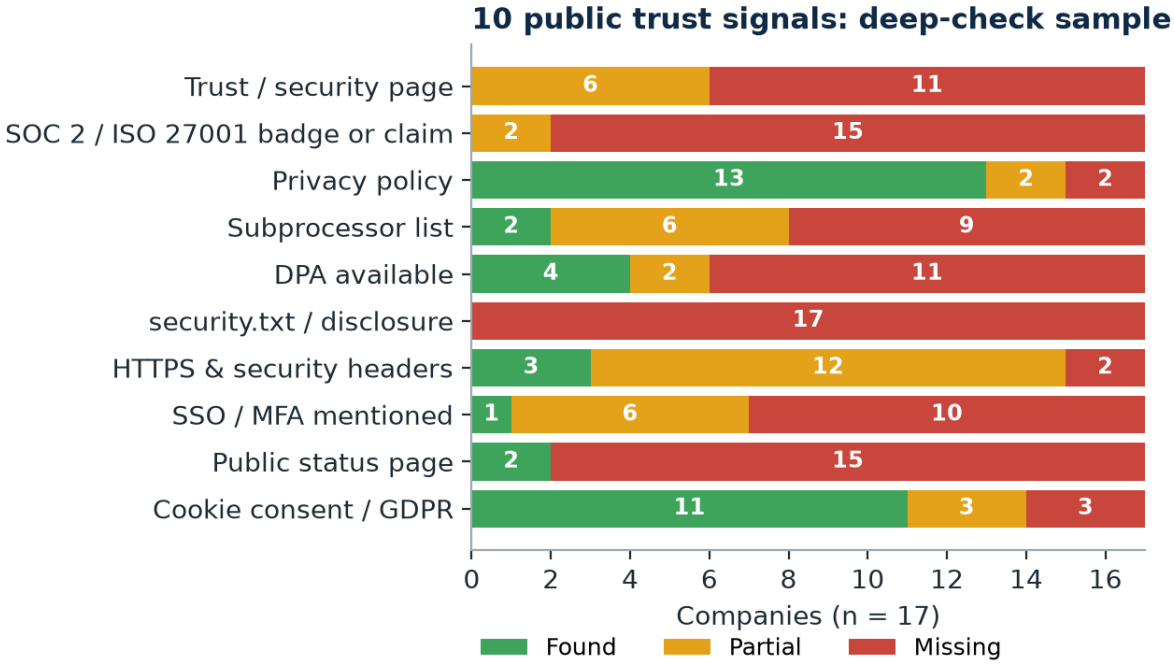


3. Deep check: companies with no public attestation

The deep sample of 17 companies with no public SOC 2/ISO/trust-center signal scored a mean of 3.26 / 10 and a median of 3 / 10 (range 1.5–6). 12 of 17 were Early (≤ 4). 5 were Developing. None reached Advanced.



The pattern is uneven. Privacy and cookie consent are relatively common. Formal security artefacts — a trust page, a verifiable attestation, a public DPA, a status page, a security.txt — are rare.



Signal-by-signal (n = 17)

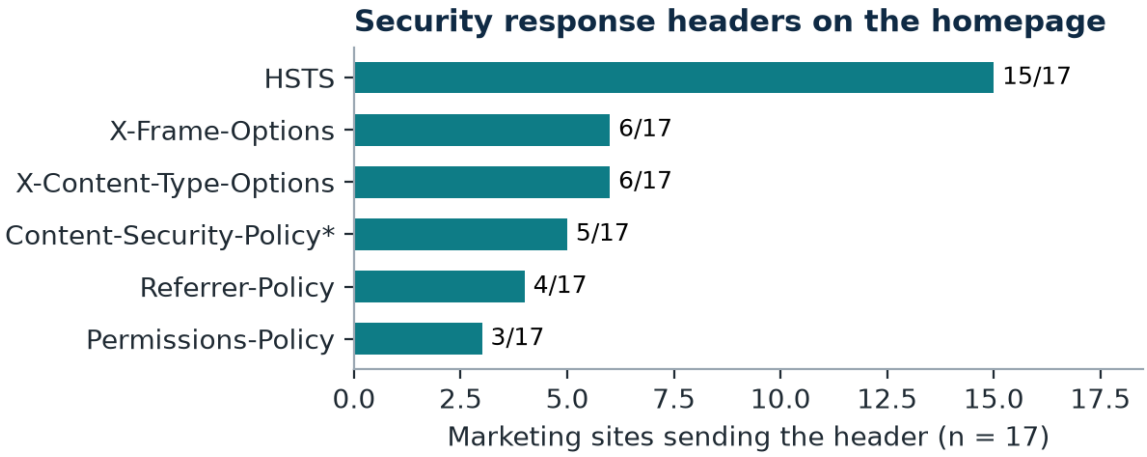
Public signal	Found	Partial	Missing	Found %
Trust / security page	0	6	11	**0%**
SOC 2 / ISO 27001 badge or claim	0	2	15	**0%**
Privacy policy	13	2	2	**76%**
Subprocessor list	2	6	9	**12%**
DPA available	4	2	11	**24%**
security.txt / disclosure	0	0	17	**0%**
HTTPS & security headers	3	12	2	**18%**
SSO / MFA mentioned	1	6	10	**6%**
Public status page	2	0	15	**12%**
Cookie consent / GDPR	11	3	3	**65%**

Notable zeros and near-zeros. 0 of 17 had a working security.txt or responsible-disclosure page. 0 of 17 had a Found (verifiable) SOC 2 or ISO 27001 badge — 2 claimed SOC 2 without a report path. Only 2 of 17 had a

public status page. Only 1 of 17 publicly mentioned SSO/MFA in a way that scored Found. Only 2 of 17 published a named subprocessor list.

4. Hygiene signals: headers and trackers

On marketing homepages, the average number of the six standard security headers present was 2.29 out of 6. 2 of 17 sent none of them (including no HSTS). Only 1 of 17 sent all six. Content-Security-Policy appeared on 5 of 17.



14 of 17 sites loaded at least one third-party analytics or marketing tracker (Google Analytics/GTM, HubSpot, Segment, PostHog, Meta, LinkedIn, Amplitude, Intercom). Cookie consent was Found on 11 of 17, Partial on 3, Missing on 3 — including sites that load trackers without a detectable banner.

5. What buyers actually check

Enterprise security and procurement teams rarely start with a pentest. They start with what is free and public, then escalate to a questionnaire. The 10 signals in our deep check map directly onto that first pass.

Trust / security page: Usually the first stop in vendor review. A missing page triggers a long questionnaire.

SOC 2 / ISO 27001 attestation: The most common hard requirement before contract. A claim without a report path is not enough.

Privacy policy: Legal baseline; reviewed by procurement and legal on every deal.

Subprocessor list: Required under GDPR Art. 28 transparency. Buyers check where their data flows.

DPA available: EU/UK customers need a signed DPA. A ready one shortens legal review.

security.txt / disclosure: Shows a working vulnerability intake. Often asked in questionnaires.

HTTPS & security headers: Visible proof of basic hygiene. Buyers' scanners check this automatically.

SSO / MFA: Enterprise IT expects SAML/OIDC SSO and MFA. Often a hard requirement.

Public status page: Shows uptime transparency and incident communication (SOC 2 availability).

Cookie consent / GDPR: EU buyers and regulators expect lawful consent. Easy to verify.

Implication for founders. A company can be 'secure' in private and still fail a public-signal review. The cheapest way to unblock the next deal is to make the truth visible: a trust page, a self-serve DPA, a subprocessor list, security.txt, and the six headers — before the SOC 2 report arrives.

5b. Anonymised vignettes from the deep sample

Four composite profiles drawn from the 17 deep-check companies. No company is named. Scores are illustrative of clusters we observed.

Profile A — 'We have a DPA, but no trust story' (score ~5–6)

A Seed payments or SaaS company with a polished privacy notice, a self-serve DPA that lists named sub-processors, a live status page, and a cookie banner. Marketing site has HSTS and a couple of headers. No security page, no SOC 2 or ISO claim, no security.txt. Buyers who start with legal paperwork will pass; buyers who start with a scanner or a trust page will bounce into a long questionnaire.

Profile B — 'We claim SOC 2 in the footer' (score ~3.5–4)

A Seed or Series A GTM/AI company whose footer or homepage says 'SOC 2 Type 2 Compliant' or 'SOC 2 Certified', with a privacy policy and a status page or cookie banner. There is no report-request form, no trust centre, no auditor named, and no public DPA or subprocessor list. Two companies in our deep sample sat here. The claim raises the bar for the next answer: if you say you have SOC 2, buyers will ask to see it.

Profile C — 'Security-led product, empty legal shelf' (score ~2.5)

An infrastructure or privacy-first product whose marketing site talks about encryption, key ownership and isolation — and whose homepage sends all six security headers. Yet there is no privacy policy, no DPA, no subprocessor list, no status page and no attestation. Technical buyers are impressed; procurement and legal still have nothing to file. The missing artefact is paperwork, not engineering.

Profile D — 'Thin public surface' (score ~1.5)

A Seed company with a working HTTPS site, a short privacy policy (or none), and almost nothing else: no trust page, no DPA, no headers beyond perhaps HSTS, no status page, no SSO/MFA mention, no cookie consent despite analytics tags. Four companies in the deep sample scored 1.5 / 10. The first enterprise questionnaire will be a cold start.

What this means for outreach

Profiles A and B are ready for a questionnaire service or a trust-page sprint. Profile C needs legal and process artefacts more than controls. Profile D needs a 45-day Audit Ready Sprint before enterprise deals are realistic. Matching the message to the profile matters more than a generic 'get SOC 2' pitch.

5c. Quick wins vs. the hard work

Not every gap takes a quarter. From the deep sample, we group remediations by typical effort for a Seed/Series A team.

Effort	What to ship	Why it moves the needle
Same day	security.txt; HSTS + the other five headers; reject-all cookie banner	0 of 17 had security.txt. Average site had 2.3 of 6 headers. Buyer scanners catch this first.
1–3 days	Public status page; named subprocessor list; self-serve DPA PDF	Only 2 of 17 had a status page; only 2 had a named subprocessor list; only 4 had a public DPA.
1–2 weeks	A real trust / security page with controls, contact and report request	11 of 17 had no trust page at all; 6 had only a thin section.
45 days	Audit Ready Sprint: gap assessment, policies, evidence mapping, mock audit	None of the deep sample had a verifiable SOC 2 or ISO 27001. This is the path to one.
3–12 months	SOC 2 Type II observation window (after Type I / readiness)	Type II needs a continuous period of evidence. Start the clock only after readiness.

Rule of thumb from this sample. If your public-trust score is under 4, spend a week on the same-day and 1–3 day items before you buy a GRC platform. If you are already answering two questionnaires a quarter, skip the week of DIY and start the Sprint.

6. Implications and recommendations

For Seed and Series A SaaS companies selling to mid-market or enterprise:

- Treat the trust page as a sales asset, not a legal afterthought. Publish what you already do.
- If you claim SOC 2, make it verifiable: a report-request form or a trust centre. A footer badge without a path invites scrutiny.
- Ship the 'quick wins' in a day: security.txt, the six security headers, a public status page, a cookie banner that offers reject-all.
- Publish a DPA and a named subprocessor list before the first EU buyer asks.
- When the same questionnaire gaps show up twice, stop answering ad hoc and get audit-ready.

How GRCompliance helps

ComplianceOS is an open-core GRC platform (self-hosted, no per-seat tax). For teams facing questionnaires now, our Security Questionnaire Service completes SIG Lite, CAIQ and custom forms at a fixed price (Express $750 / Standard $1,500 / Retainer $2,500/mo). For teams ready to stop renting trust, the Audit Ready Sprint gets you to audit-ready in 45 days: $14,492 in year one with the Professional licence, or $16,892 one-time with Lifetime. The independent auditor's fee is billed separately.

Want a free public-signal snapshot of your company?

Reply with your domain, or book a 20-minute call. We will send a one-page Readiness Snapshot based only on public information — the same method used in this report.

Dante Wells · GRCompliance · grcompliance.com · [email] · Book: [calendar link]

Appendix A — Scoring rubric

Found: clear public evidence (page, document or header) that a buyer can verify without access. Partial: a claim, an on-request offer, a thin page, or incomplete headers. Missing: not found on the site or related public hosts. Score = Found×1 + Partial×0.5.

Appendix B — Data sources

- targets_saas.csv — 104 Seed-to-Series-A/B SaaS companies, compliance_signal column (yes / no / unknown).
- /workspace/snapshots/summary.csv and /workspace/snapshots/raw — deep-check evidence for 17 companies (14 Oct 2026).
- HTTP response headers via curl/requests; DNS via dns.google; page content via browser dump-dom. No active scanning.

Appendix C — About GRCompliance

GRCompliance builds ComplianceOS, an open-core GRC platform for SOC 2, ISO 27001, HIPAA, GDPR and NIST. Self-hosted. Unlimited users. Audit Ready Sprint and Security Questionnaire Service available as fixed-scope add-ons. grcompliance.com.

© 2026 GRCompliance. This report may be shared with attribution. Company names in the underlying data are withheld from this public version.